

Aula 2 (Módulo 08) — TP vs. FP, Severidade, Priorização, Case Management e SLA

1. True Positive vs. False Positive — o vocabulário central

Toda triagem termina em uma dessas classificações:

- **True Positive (TP)**: o alerta estava **certo** — houve, de fato, atividade maliciosa/suspeita real por trás dele.
- **False Positive (FP)**: o alerta disparou, mas **não havia** ameaça real — foi comportamento legítimo que só "parecia" suspeito para a regra de detecção.

Duas variações que também aparecem bastante:

- **False Negative (FN)**: o pior cenário — houve um ataque real, mas **nenhum alerta disparou** (a detecção falhou silenciosamente). É descoberto geralmente depois, durante Threat Hunting ou já como incidente confirmado por outro meio.
- **True Negative (TN)**: nada de suspeito aconteceu, e nenhum alerta disparou — o "silêncio esperado", que na prática não aparece como item de trabalho (não gera alerta nenhum).

		Havia ameaça real?	
		SIM	NÃO
Alerta disparou?	SIM	True Positive	False Positive
	NÃO	False Negative	True Negative

Por que importa: um SOC é avaliado, entre outras coisas, pela proporção de FP no volume total de alertas. Uma taxa de FP muito alta causa **alert fatigue** (fadiga de alerta) — analistas ficam dessensibilizados e começam a triar tudo mais rápido e com menos cuidado, aumentando o risco de um TP real passar despercebido (virando, na prática, um FN). Reduzir FP através de **tuning** de regras (Módulo 21) é um trabalho constante, não uma tarefa que "termina" algum dia.

2. Severidade — o quão grave é, SE for real

Severidade normalmente usa uma escala (comum: Crítica, Alta, Média, Baixa, Informativa), definida por fatores como:

- **Impacto potencial**: um alerta em um servidor de produção crítico pesa mais que o mesmo alerta numa estação de trabalho comum.
- **Confiança da detecção**: uma regra baseada em assinatura muito específica (Módulo 04, Aula 1) costuma ter confiança maior que uma baseada em anomalia genérica.
- **Estágio do ataque** (lembrando do MITRE ATT&CK que veremos no Módulo 13): uma tentativa de reconhecimento inicial geralmente pesa menos que um sinal de exfiltração de dados já em andamento.

Importante: severidade é sobre **"se for real, quão grave é"** — não deve ser confundida com "quão certo estou que é real" (isso é outra dimensão, às vezes chamada de **confiança**). Um alerta pode ser de **alta severidade e baixa confiança** ao mesmo tempo (ex.: um possível indício de ransomware, mas com poucos dados para confirmar) — e isso ainda merece atenção rápida, justamente por causa do impacto potencial se for verdadeiro.

3. Priorização — decidindo a ordem de trabalho

Com múltiplos alertas na fila, a ordem de atendimento normalmente combina severidade + confiança + **contexto do ativo afetado**:

Prioridade $\approx$ Severidade $\times$ Confiança $\times$ Criticidade do ativo

Um alerta de severidade média, mas em um **domain controller** (que vamos estudar no módulo de Active Directory) — um ativo extremamente crítico — pode furar a fila na frente de um alerta de severidade alta em uma máquina de teste isolada. Isso exige que o SOC tenha, de antemão, um **inventário de ativos críticos** (chamado às vezes de *crown jewels* — "joias da coroa") bem definido.

4. Case Management — onde tudo fica documentado

Um **case** (ou ticket) é o registro formal de um alerta/investigação, geralmente em uma ferramenta dedicada (ex.: TheHive, Jira, ServiceNow, ou o módulo de casos do próprio SIEM). Um case bem documentado inclui:

- Timestamp de abertura, analista responsável;
- Resumo do alerta original e por que foi escalado (ou não);
- Cada passo da investigação, com evidências (logs, screenshots — lembra da pasta `screenshots/` deste repositório?);
- Classificação final (TP/FP), severidade final, e ação tomada;
- Se virou incidente: link para o processo de IR (Módulo 15).

Por que importa: um case bem documentado permite que **qualquer outra pessoa** do time retome a investigação exatamente de onde parou (ex.: troca de turno), serve de base para métricas do SOC, e — em ambientes regulados — pode ser exigido como evidência de conformidade (auditoria, forense legal).

5. SLA — o compromisso de tempo

SLA (*Service Level Agreement*) define o tempo máximo aceitável entre etapas do processo — os mais comuns em SOC:

- **Tempo até a triagem inicial** (ex.: "todo alerta crítico deve ser triado em até 15 minutos").
- **MTTD** (*Mean Time to Detect*): tempo médio entre o ataque acontecer e ser detectado.
- **MTTR** (*Mean Time to Respond/Resolve*): tempo médio entre a detecção e a resposta/contenção efetiva.

Por que importa: esses números costumam ser exatamente o que a liderança de segurança de uma empresa acompanha para saber se o SOC está funcionando bem — um SOC tecnicamente competente, mas lento demais para agir, ainda deixa a organização exposta pelo tempo que o atacante tem livre entre comprometer algo e ser contido.

6. Conectando tudo

Alerta → Triage (Aula 1) → classificado como TP ou FP

TP → severidade + confiança + criticidade do ativo → priorização

→ vira um case documentado → resposta (Módulo 15) dentro do SLA

FP → documentado com justificativa (alimenta tuning futuro, Módulo 21)

7. Exercício de reflexão

Dado este cenário resumido — sem eu te dar a resposta pronta, tente raciocinar com o que aprendemos:

Um alerta dispara: "múltiplas falhas de login SSH seguidas de um login bem-sucedido", no servidor que hospeda o site principal da empresa (ativo crítico).

1. Isso deveria ser classificado, inicialmente, como TP ou FP? O que faltaria saber para ter certeza?
2. Que severidade você atribuiria, considerando que é um ativo crítico?
3. Que informação você registraria no case, mesmo antes de terminar a investigação completa?

8. Recapitulando

- TP = alerta certo, ameaça real; FP = alerta errado, sem ameaça; FN = ameaça real sem alerta (o cenário mais perigoso); TN = silêncio correto.
- Severidade mede impacto potencial **se** for real; confiança mede o quão certo você está que é real — são dimensões diferentes.
- Priorização combina severidade, confiança e criticidade do ativo afetado.
- Case management documenta toda a investigação para continuidade, métricas e auditoria; SLA mede o tempo de resposta do SOC (MTTD, MTTR).

Próxima aula (fecha o Módulo 08)

Como funciona uma investigação de alerta na prática — a metodologia completa que você vai usar toda vez que eu te entregar um `ALERTA

00X` para investigar ao vivo.

Fontes recomendadas

- **NIST SP 800-61 Rev. 2**: já citada na Aula 1 — também cobre priorização de incidentes por impacto funcional/informacional/de recuperabilidade. <https://csrc.nist.gov/pubs/sp/800/61/r2/final>
- **FIRST — "Common Vulnerability Scoring System (CVSS)"**: embora focado em vulnerabilidades (não alertas), o modelo de pontuação de impacto do CVSS é uma referência comum ao pensar em severidade. <https://www.first.org/cvss/>

